COMPTIA SECURITY+ SY0-701 | DOMAIN 2 · THREATS, VULNERABILITIES, AND MITIGATIONS (22%)

Security+ 2.4 · Other Malware Types

Mestre CyberSec · **Lesson 2.4 — Other Malware Types** (7:32) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Keylogger: grava digitação — rouba senha em texto claro. Logic bomb: detonada por evento (data, demissão, tecla) — dorme até o gatilho. Rootkit: esconde no KERNEL — invisível pra antivírus comum (precisa de limpeza/reinstall). Trojan: finge ser legítimo. Backdoor: porta que o ata

💡 Key Exam Highlights & Critical Concepts

- Rootkit esconde no KERNEL do sistema: quase invisível (boot from known-good media pra detectar)
- Keylogger: grava tudo em texto claro — rouba senha no envio
- Logic bomb: detonada por EVENTO (data/demissão/action)

🎯 Exam Tips & Typical CompTIA Scenarios

- 'malware that hides itself within the OS kernel' = rootkit
- 'dormant until triggered by a specific event' = logic bomb

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 2.4 — Other Malware Types)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Keylogger (N/A)

Software or hardware that records every keystroke typed by a user, capturing credentials and sensitive data in plaintext before encryption.

⚠️ ***Exam Trap:*** *Exam trigger: 'captures keystrokes in plaintext' or 'records what a user types'. Hardware keyloggers are physically inline between keyboard and motherboard; software keyloggers are often rootkit-based.*

• Logic Bomb (N/A)

Malicious code that remains dormant until a specific trigger condition is met (date, time, event, user action, or termination), then executes its payload.

⚠️ ***Exam Trap:*** *Exam trigger: 'dormant until triggered by a specific event' or 'executes when condition is met'. Distinct from time bombs (date-based) vs. event-based triggers like employee termination.*

• Rootkit (N/A)

Malware that embeds itself deep within the operating system kernel or boot sector to maintain privileged, stealthy access and evade standard antivirus detection.

⚠️ ***Exam Trap:*** *Exam trigger: 'malware that hides within the OS kernel' or 'invisible to standard AV'. Detection requires boot from known-good/clean media. Often necessitates full OS reinstallation.*

• Trojan (Trojan Horse) (N/A)

Malware disguised as legitimate, useful software to trick users into installing it, then delivering a hidden malicious payload.

⚠️ ***Exam Trap:*** *Exam trigger: 'disguised as legitimate software' or 'user must be tricked into running it'. Does NOT self-replicate (unlike viruses/worms). Classic example: fake antivirus or game cracks.*

• Backdoor (N/A)

An undocumented or hidden access point in software or a system that bypasses normal authentication, allowing remote attacker access.

⚠️ ***Exam Trap:*** *Exam trigger: 'unauthorized access point' or 'bypasses normal authentication'. Often left by developers OR installed by Trojans. Closely linked with RATs (Remote Access Trojans).*

• Spyware (N/A)

Malware that covertly gathers information about a user's activities, browsing habits, credentials, or personal data without consent.

⚠️ ***Exam Trap:*** *Exam trigger: 'covertly gathers user information' or 'monitors browsing habits'. Distinguished from keyloggers (broader data capture) and adware (specifically ad-driven).*

• Adware (N/A)

Software that automatically displays or downloads unwanted advertisements, often bundled with free software and potentially collecting marketing data.

⚠️ ***Exam Trap:*** *Exam trigger: 'displays unwanted advertisements' or 'bundled with free software'. Not always malicious but crosses into malware when it tracks behavior without consent (grayware).*

• Ransomware (N/A)

Malware that encrypts user files or locks the system, demanding payment (ransom) typically in cryptocurrency for decryption keys.

⚠️ ***Exam Trap:*** *Exam trigger: 'encrypts files and demands payment' or 'crypto-malware'. Modern variants use double/triple extortion (encrypt + leak + DDoS). Backups are the primary defense.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Trojan Horse vs. Remote Access Trojan (RAT)

🏠 **Real-World Analogy:** The legendary Trojan Horse was an ornate wooden gift that the citizens of Troy rolled voluntarily through their fortified gates, believing it was an offering to the gods; at midnight, hidden soldiers emerged from its belly to open the city gates. A software Trojan behaves identically: it masquerades as a harmless utility or free tool that the user gladly downloads. A Remote Access Trojan (RAT) takes this further: once inside, the covert operatives install ceiling microphones, 360-degree cameras, and a remote control interface enabling an attacker across the world to watch the user's webcam, harvest keystrokes, and upload confidential files at will.

🔍 **Root Cause & Background:** Trojans weaponize social engineering against the human layer. Because authenticated users deliberately authorize the installer, perimeter firewalls treat the download as legitimate web traffic. Once executed, the embedded RAT component opens an outbound reverse shell back to the adversary's command node, effortlessly traversing standard inbound firewall blocks.

🛡️ **GRC Auditor Perspective:** Enforce Software Allowlisting (such as Windows AppLocker or WDAC) ensuring only pre-approved, cryptographically signed executables can run; strip local administrative rights from all standard workstations; and monitor anomalous persistent outbound interactive sessions tunneled across non-standard or encrypted ports.

⚠️ **How CompTIA Tests This:** Trigger: 'software disguised as a legitimate tool while covertly executing unauthorized actions in the background'. Answer: Trojan. Trigger: 'malware providing an external attacker with unauthorized interactive remote desktop or shell access, including webcam and mic surveillance'. Answer: Remote Access Trojan (RAT).

📌 Rootkits & Kernel-Level Privilege (Ring 0 Manipulation)

🏠 **Real-World Analogy:** Imagine suspecting an intruder inside your building, so you ask the chief security supervisor to review camera logs and visitor manifests. Unbeknownst to you, the intruder bribed the chief supervisor, granting them supreme authority over building records. The supervisor cuts the security feed in real time and deletes the intruder's name from the official register before handing you the report. You inspect the log and conclude the facility is secure. The Kernel (Ring 0) represents this supreme authority: once a rootkit seizes Ring 0, the OS itself deceives the Task Manager and antivirus, reporting that the rogue process does not exist.

🔍 **Root Cause & Background:** Modern x86/x64 microprocessors enforce hierarchical hardware privilege rings: Ring 3 for unprivileged user space applications and Ring 0 for the operating system Kernel and core drivers. If an adversary gains Ring 0 execution (via compromised driver signatures or kernel memory flaws), they hook native kernel system calls (syscalls), selectively filtering OS output to conceal files, registry keys, and network sockets from diagnostic tools.

🛡️ **GRC Auditor Perspective:** Enforce mandatory Driver Signature Enforcement, UEFI Secure Boot, and hardware TPM measurement baselines. When a kernel-mode rootkit is confirmed on an enterprise endpoint, Incident Response governance mandates an immediate teardown: never rely on in-place antivirus disinfection; wipe physical drives and restore the endpoint from a known-good baseline (Full Rebuild / Reimage).

⚠️ **How CompTIA Tests This:** Trigger: 'malware operating at kernel level (Ring 0) that hooks system calls to conceal its processes, sockets, and files from administrative utilities'. Answer: Rootkit. CompTIA-mandated remediation procedure: Rebuild / reimage the infected host.

📌 Double Extortion Ransomware

🏠 **Real-World Analogy:** In traditional ransomware (single extortion), an intruder breaks into your home, fastens a personal padlock to your private safe, and demands cash for the key; if you keep a complete duplicate of your files in a secure offsite safety deposit box (a pristine offline backup), you refuse payment and restore seamlessly. In response, cyber syndicates engineered Double Extortion: before locking your safe, they photograph all your trade secrets, patient medical histories, and executive communications, warning: 'Even if you restore from backups, if you do not pay, we will publish your confidential files on a public leak site tomorrow.'

🔍 **Root Cause & Background:** As enterprise disaster recovery matured, organizations widely deployed immutable storage (WORM) and air-gapped offline backups, severely diminishing ransom yield from pure encryption attacks. To regain leverage, ransomware operators adopted data exfiltration prior to payload execution, weaponizing regulatory non-compliance penalties (GDPR/HIPAA/LGPD) and catastrophic brand degradation on dedicated leak sites.

🛡️ **GRC Auditor Perspective:** Offline backups are no longer an adequate standalone defense against modern ransomware. Auditors must verify: Data Loss Prevention (DLP) gateways alerting on massive anomalous outbound file transfers; strong encryption at rest for sensitive data repositories; and tested Incident Response playbooks with legal and PR workflows to fulfill mandatory breach notification deadlines (e.g., 72-hour GDPR reporting).

⚠️ **How CompTIA Tests This:** Trigger: 'attackers encrypt corporate servers and threaten to publish stolen proprietary data on a public website unless a ransom is paid'. Answer: Double Extortion Ransomware. Distractor alert: Having verified backups restores operational availability, but does not mitigate the confidentiality breach of the exfiltration threat.

📌 Logic Bomb & The Disgruntled Insider Threat

🏠 **Real-World Analogy:** An electrician laid off from a hospital project conceals a hidden timer circuit behind the ICU distribution board, configured to cut emergency power on December 31st, or whenever his employee badge number is deleted from the human resources payroll system. As long as the electrician remains on the payroll, the circuit sleeps undetected. The moment HR processes his termination and purges his account, the logic condition is satisfied and the timer triggers a total electrical blackout.

🔍 **Root Cause & Background:** Disgruntled insiders with elevated systems access exploit their privileges to embed dormant conditional routines ('if condition X evaluates to true, trigger destructive action Y') into production scripts or databases. Because the malicious code remains completely inert until an external condition is met (a specific calendar date, an HR account deletion, or an unfulfilled ping), it bypasses regular operational testing.

🛡️ **GRC Auditor Perspective:** Audit the strict execution of Employee Offboarding procedures: immediate suspension of all directory credentials prior to in-person dismissal meetings; mandatory Peer Code Review and segregation of duties across development pipelines; and continuous file integrity monitoring (FIM) tracking unapproved modifications to administrative scripts.

⚠️ **How CompTIA Tests This:** Trigger: 'dormant malicious routine planted by a disgruntled IT worker that executes and wipes corporate files only when an employee account is disabled in the directory'. Answer: Logic Bomb. Essential GRC preventive control: Immediate credential revocation during employee offboarding.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Program masquerading as a legitimate utility while covertly installing unauthorized backdoor tools	**Trojan Horse**
Malware granting an external adversary full interactive remote GUI/shell control, including desktop and webcam surveillance	**Remote Access Trojan (RAT)**
Kernel-level malware (Ring 0) intercepting system calls to conceal its presence, processes, and network ports from the OS	**Rootkit (remediation procedure: Reimage / reinstall OS)**
Adversaries encrypt enterprise servers and threaten to leak exfiltrated sensitive files publicly unless a ransom is paid	**Double Extortion Ransomware**
Dormant code embedded by a disgruntled employee that executes file deletion if a date occurs or the user is terminated	**Logic Bomb**
Primary GRC control to prevent data sabotage when terminating a disgruntled system administrator	**Immediate Offboarding Credential Deprovisioning**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A financial analyst reports that credentials for an internal banking portal were stolen even though the portal uses HTTPS. Forensic review shows a small user-mode process on the analyst's workstation intercepting keyboard input before the browser encrypts it. Which malware type best matches this behavior?

A) Keylogger

B) Rootkit

C) Logic bomb

D) Adware

QUESTION 2 · EXAM SCENARIO

A former contractor leaves a script on a file server. The script checks every hour and, if the contractor's HR record is marked terminated, deletes project archives and disables backups. The code remains dormant for weeks until that condition occurs. Which malware type is this?

A) Ransomware

B) Rootkit

C) Logic bomb

D) Trojan horse

QUESTION 3 · EXAM SCENARIO

During incident response, analysts find that a compromised Linux server reports normal process lists and antivirus scans show no infection. However, kernel system call tables have been modified, and a malicious driver hides files and network connections. Which malware type is most likely present?

A) Keylogger

B) Rootkit

C) Adware

D) Logic bomb

QUESTION 4 · EXAM SCENARIO

An employee downloads what appears to be a free PDF-to-Word converter from a pop-up advertisement. The program converts PDFs as promised, but it also installs a remote access service that listens for commands from an external IP address. Which malware type best describes the converter?

A) Keylogger

B) Ransomware

C) Logic bomb

D) Trojan horse

QUESTION 5 · EXAM SCENARIO

After a workstation is cleaned of a previous malware infection, the security team observes recurring inbound connections to a high TCP port. Further analysis shows a hidden service that accepts commands using a hard-coded credential, allowing access without exploiting the original vulnerability again. What mechanism is this?

A) Backdoor

B) Rootkit

C) Spyware

D) Logic bomb

QUESTION 6 · EXAM SCENARIO

An endpoint security tool alerts on a process that periodically sends browsing history, clipboard contents, and application window titles to an external server. Users report no pop-up ads, and no files have been encrypted. Which malware category best matches this activity?

A) Adware

B) Spyware

C) Ransomware

D) Logic bomb

QUESTION 7 · EXAM SCENARIO

Employees who installed a free screensaver package report frequent pop-up advertisements, changed browser homepage, and new search toolbars. No credentials or documents appear to have been stolen. Which malware category is most likely involved?

A) Spyware

B) Keylogger

C) Adware

D) Rootkit

QUESTION 8 · EXAM SCENARIO

A hospital's shared drive files are replaced with encrypted versions that have a .locked extension. A text file on each affected system demands cryptocurrency payment in exchange for a decryption key. Which malware type is responsible?

A) Rootkit

B) Trojan horse

C) Adware

D) Ransomware

QUESTION 9 · EXAM SCENARIO

A compromised server is confirmed to have kernel-level malicious code that hides processes and modifies system calls. The operating system cannot be trusted, and the incident response team needs the most reliable way to remove the threat. What should the team do?

A) Run a full antivirus scan and delete detected files

B) Wipe the server and reinstall the OS from trusted media

C) Remove the malicious process from Task Manager

D) Change all local administrator passwords

QUESTION 10 · EXAM SCENARIO

A security analyst suspects a workstation is capturing user credentials before they are encrypted by the browser. The analyst has both host-based and network monitoring available. Which data source is most likely to reveal this activity?

A) Network packet capture filtering only HTTPS traffic

B) Perimeter firewall logs showing blocked inbound connections

C) Host-based API and keystroke monitoring on the workstation

D) DNS query logs for the banking portal domain

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option A — Keylogger

A keylogger captures keystrokes at the input layer before TLS/HTTPS encryption, so it can steal credentials in clear text. Rootkits hide at kernel level, logic bombs trigger on specific events, and adware displays unwanted advertising. HTTPS does not protect against local keystroke capture.

Question 2: Option C — Logic bomb

A logic bomb is dormant code that executes a malicious payload when a specific trigger occurs. Here the trigger is the HR termination status, after which it deletes archives and disables backups. Ransomware demands payment, rootkits hide in the kernel, and Trojans disguise themselves as legitimate software.

Question 3: Option B — Rootkit

A rootkit often modifies kernel components or system calls to conceal files, processes, and connections from normal tools and antivirus. Keyloggers capture input, adware displays ads, and logic bombs trigger on events. Kernel-level hiding points to a rootkit.

Question 4: Option D — Trojan horse

A Trojan horse appears to perform a legitimate function while secretly performing malicious actions. The converter works as advertised but also installs a remote access service. A keylogger captures keystrokes, ransomware encrypts for payment, and a logic bomb waits for a trigger.

Question 5: Option A — Backdoor

A backdoor is a hidden access mechanism that lets an attacker reconnect without re-exploiting the original vulnerability. It may use a listening service and hard-coded credentials. A rootkit conceals activity, spyware collects information, and a logic bomb triggers on an event.

Question 6: Option B — Spyware

Spyware covertly collects user activity and data, such as browsing history, clipboard contents, and window titles. Adware focuses on unwanted advertisements, ransomware encrypts files for payment, and logic bombs trigger a payload on an event. The stealthy data collection is spyware.

Question 7: Option C — Adware

Adware displays unwanted advertisements and often changes browser settings, such as the homepage and search toolbars. Spyware stealthily collects information, a keylogger captures keystrokes, and a rootkit hides at the kernel level. The ad-focused symptoms point to adware.

Question 8: Option D — Ransomware

Ransomware encrypts data and demands payment for a decryption key. A Trojan may deliver it, but the described payload is extortion through encryption. Rootkits hide activity, and adware displays advertisements.

Question 9: Option B — Wipe the server and reinstall the OS from trusted media

Kernel-level compromise makes the operating system untrustworthy, so the most reliable remediation is to wipe the server and reinstall the OS from trusted media. Antivirus may not detect kernel-hidden code, killing a process is insufficient, and changing passwords does not remove the malicious kernel components.

Question 10: Option C — Host-based API and keystroke monitoring on the workstation

If credentials are captured before browser encryption, the activity occurs locally on the workstation. Host-based API and keystroke monitoring can detect this. HTTPS packet capture would show encrypted traffic, firewall logs show blocked connections, and DNS logs show domain lookups but not keystrokes.